

GuardianX 작업지시서

거절은 도달이 아니다 · 결합 규칙 판정 · MinIO 착수

2026-09-17 Code 보고를 읽고 낸다. 게이트가 처음으로 옳은 색을 냈다 — 초록 6 · 빨강 1 · 회색 0 · 대기 2. 가장 큰 발견은 「자격증명을 넣었더니 초록이 났다」: 401을 「문지기가 섰다」로 읽는 규칙이 들어가지 못한 채 초록을 만들고 있었다. Code는 규칙이 아니라 증거로 고쳤다.

§0 원칙 — 착시 ㉑형 · 문지기형

「거절(401/403)은 살아 있다는 증거이지 기능의 증거가 아니다. 적어 두는 것으로는 안 막힌다 — 증거로 막는다.」

파일 첫머리에 「가장 나쁜 실패」라고 적어 두었는데도 막히지 않았다. 주석은 게이트가 아니다. 로그인 뒤 익명으로 한 번 더 때려 토큰이 바꾼 것을 세고, 0건이면 판정 불가 — 이것이 증거다.

6·1·0·2

게이트 세 수 + 대기 [실측]
통과·실패·못 잤 대기

24/26

401인데 exit 0이던 것
→ 착시 ㉑형

1

시크릿 실제 발견 [실측]
CSRF 하드코딩 · 비율

P-16

결합 규칙 판정
불인다 · K1 소비자로

P-15

인증 경로 대장
JWT 거절은 누구의 문제?

회색은 세 종류였고, 401은 도달이 아니었다

1 게이트 — 처음으로 옳은 색

Code [실측] 2026-09-17 · 직전 통과 4 · 못 잤 5

회색 다섯의 실체	자리	처분	세종 판정
진짜 빛 2	route-alive(자격증명) · secrets(스캐너)	값음 → 잤	인정
잘못 칠한 색 1	bypass — 잤고 알면서 SKIP	래킷으로 옮겨 PASS (D-311)	인정. 아는 빛은 회색이 아니라 래킷
빛이 아닌 것 2	model-inheritance · ui-library — 볼 대상 0	「대기」 신설, 없애지 않음	인정 (P-12 ④)

2 자격증명을 넣었더니 초록이 났다 — 착시 ㉑형

자격증명 불입 → 게이트 exit 0

→

26건 중 24건 401 — JWT를 dj-core가 거절 (user.token 없음)

→

규칙 「401 = 문자기가 썼다」가 초록을 만들

→

증거로 고침: 로그인 뒤 익명 재타격 · 토큰이 바꾼 수 0이면 판정 불가 → 500 두 자리 드러남 → exit 1

착시 ㉑형 — 문자기형. 거절(401/403)을 도달로 읽는다. 문자기가 썼다는 것은 살아 있다는 증거이지 기능의 증거가 아니다. ㉑ 봉투형(200 안의 403)의 거울상이다 — 저쪽은 실패를 성공으로, 이쪽은 거절을 도달로. 대장에 올려라.

원칙. 「적어 두는 것으로는 안 막힌다 — 증거로 막는다.」 그 파일 첫머리는 스스로 「가장 나쁜 실패」라 적어 두었고 그대로 일어났다. 주석은 게이트가 아니다. 이 문장을 verify_* 공통 머리말에 넣어라.

3 시크릿 · 오탐 · 저장소 게이트

항목	보고 [실측]	세종 판정
시크릿	파일 면 19 · 이력 면 1. 발견 1건 example_frontend.html:813 하드코딩 CSRF — 유출이면서 기능 결함(대체 경로 세 갈래가 안 됨). 측정기 결함 둘(허용목록 100KB 넘으면 조용히 꺼짐 · check-ignore CRLF)	인정. +1: 그 값이 실제 환경 발급본이었나 확인, 그렇다면 무효화(D-004 · 이력 재작성 금지)
오탐 ① 결합 규칙	「돌아가는 듯하다」는 추정이었다. review_event는 response_state를 건드리지 않는다. 「수는 원인을 말하지 않는다」	인정. 판정은 §1 (P-16)
저장소 게이트	verify_tool_selftest(출생 표본 없음) · verify_homonyms(맨 api_key)가 커밋을 먼저 막음	둘 다 옳다. 동음이의 대장이 일한다
온보딩 %	세종 판정 44%를 옮기지 않았다 — 실측이 아니라서	옳다. P-11 전엔 「미측정」

불린다 — 그러나 코드에서는 맞물리지 않게

Code의 물음: REJECTED → response_state=closed 자동 결합을 불이면 D-399가 가른 두 축이 다시 맞물린다. 불일 것인가. **불린다**. 사용자에게는 같은 일이다(D-378) — U1이 「오탐」을 누른 뒤 「종결」을 또 눌러야 하면 두 종류의 종결을 보게 되고, 그것이 P-1 화면 규칙이 막으려던 것이다. 그러나 코드에서 두 축이 서로를 쓰게 하지는 않는다.

판정 축 · 기준

review_event → verdict

response_state를 쓰지 않는다. 「verdict 바뀜」 이벤트만 낸다(이미 K1 이벤트가 있으면 그것).

결합 · P-16 · 단 한 곳

K1 소비자 1개

on verdict=REJECTED

→ response →

closed/false_positive

행위자 system:false_positive. 감사에 남는다. K1_CONSUMERS 등록 · WRITE_PROBES 등록(P-8).

대응 축 · P-1

response_state 전이

verdict를 절대 쓰지 않는다. 재판정 (REJECTED → CONFIRMED) 뒤에도 closed 그대로 — U2가 되돌림(사유 필수)으로 연다.

P-16 오탐 결합 규칙 — K1 소비자 1개

판정 · 쓰기 면 → P-8

- K1_CONSUMERS에 등록(직전 턴 게이트가 「소비자 미등재」를 잡은 그 등록부). 쓰기 면이므로 P-8 순서: WRITE_PROBES 등록 → 격리 시험 빨감 → 구현 → 초록.
- 역방향 없음. 결합은 이 소비자 한 곳에만 — 다른 자리에 두 축을 잇는 코드가 생기면 버그다(09-15 지시서 4p 표의 「유일한 예외 B-2」).
- 시드 재점검: 시드가 rejected 4건의 대응 축을 직접 달던 호출을 빼고, 소비자가 달는지 [실측]. 「수는 원인을 말하지 않는다」 — 이번엔 원인이 소비자여야 한다.

시험 3 — ① REJECTED → closed/false_positive 자동 1건 ② CONFIRMED 재판정 후 response_state 불변 1건 ③ 다른 테넌트의 verdict 이벤트에 반응하지 않음 1건(격리 탐침).

오탐 ②③④ 같은 묶음 — 라우트 · 통지 · 오탐률

서비스 있음·라우트 없음 [실측]

- ② 판정 API 라우트 1개 잇기(쓰기 면 → P-8). 거절은 4xx, 코드를 나눈다(09-15 P-1과 같이).
- ③ 오탐 종결 통지 — 알림이 나간 이벤트가 REJECTED 되면 원 수신자에게 1회. 로그 어댑터. 쓰기 면 → P-8.
- ④ 오탐률 = REJECTED / 전체(기간·카메라·시나리오) → K6 계측 1개. W1 「지난 12시간」 요약 한 줄의 「오탐 N」이 이 수를 읽는다(P-13).

1.1 왜 직접 쓰기가 아니라 소비자인가

방식	코드에서 일어나는 일	D-293 · P-1과의 관계	판정
review_event가 response_state를 직접 씀	판정 축 함수 안에 대응 축 쓰기가 들어간다. 두 축의 코드가 서로를 안다	D-293이 가른 것을 한 함수에 다시 섞는다. 테넌트 격리 탐침도 판정 면 하나로 두 쓰기를 봐야 한다	기각
K1 소비자 1개 (P-16)	판정 축은 이벤트만 낸다. 소비자가 그 이벤트를 받아 대응 축 전이를 부른다. 행위자 system:false_positive	두 축 코드는 서로 모른다. 결합은 소비자 한 곳 — 끄면 두 축은 완전히 독립. 격리는 소비자 자체가 탐침 대상	채택
결합 없음 (사람이 두 번 누름)	—	코드는 가장 깨끗하나 사용자가 두 종류의 종결을 본다 — P-1 화면 규칙 위반	기각

1.2 표 B 다시 — 소비자가 있을 때의 시간순

09-15 지시서 4p 표 B의 갱신

#	일어난 일	verdict	response_state	누가 썼나 (감사)
1	생성 · 알림 → U1 접수 · 조치 중	—	in_progress	U1 (acknowledge · start)
2	U1이 「오탐」 (그림자)	REJECTED · reject_reason	in_progress → closed / false_positive	verdict: U1 · response: system:false_positive (소비자) · 통지 1회(③) · K6 오탐률 +1(④)
3	U2가 재판정 「진짜였다」	REJECTED → CONFIRMED	closed (불변)	verdict: U2 · response: 아무도 — 역방향 없음
4	U2가 대응을 다시 연다	CONFIRMED	closed → in_progress (되돌림 · 사유)	response: U2 · 감사에 2·3·4 모두 남음

JWT 거절은 게이트만의 문제인가

/api/token/pair가 준 JWT를 dj-core가 user.token 없다고 거절했다(core/auth.py:38). 게이트는 다른 길로 들어갔다. 그러면 실제 클라이언트는 어느 길로 들어가나? 모바일 M1~M3(다음 순서)은 로그인 첫 화면이다. 죽은 길 위에 화면을 세우지 않는다. 「토큰」이라는 말이 지금 셋(JWT · user.token · api_key)일 가능성이 크다 [추정] — 동음이의 대장의 일이다.

P-15 인증 경로 대장 — 면마다 어느 문으로 들어가나

판정 · docs/agent/authn_paths.md

- 면(웹 UI · 모바일 M1~M3 · 외부 API U6 · 게이트 · 시드)마다 한 줄: 「어느 인증(세션 / user.token / JWT pair / api_key) · 실측 결과(200/401) · 근거 경로」.
- /api/token/pair 처분: 실제 클라이언트가 쓰지 않으면 ㉔(제거, 대장에 남김). 쓰는데 거절되면 그것이 버그다 — 어느 쪽인지 [실측] 후 처분. **dj-core는 고치지 않는다(D-207)** — 바깥에서 잇거나 뺀다.
- 동음이의 대장 authn 항목 갱신: 「토큰」이 셋이면 이름을 갈라라(직전 턴 verify_homonyms가 맨 api_key를 잡은 그 방식).
- M1~M3는 이 대장이 확정한 길 하나로만 로그인한다. 무계정 링크 금지는 그대로.

강제 도구 — 대장의 각 면을 그 인증으로 1회 때려 200 [실측]. 게이트가 한 것과 같은 「증거로」: 로그인 뒤 익명 재타격으로 토큰이 바뀔 수 > 0.

2.1 대장 예상 모양 — Code가 실측으로 채운다

면	인증 [추정]	실측	근거 경로	처분
웹 UI (16화면)	세션 또는 user.token	□	□	—
모바일 M1~M3	대장 확정 길 하나	□	□	P-15 뒤에 세운다
외부 API (U6)	api_key (F-05)	□	□	—
게이트 route-alive	게이트가 들어간 길	1 (죽은 라우트 2)	689e064	—
시드 (P-9)	K1 진입 API	□	□	—
/api/token/pair	JWT — dj-core 거절	401 [실측]	core/auth.py:38	㉔ 잇기 / ㉔ 제거 — 실측 후

2.2 동음이의 대장 · authn — 「토큰」이 셋일 때

[추정] · Code 실측으로 확정

지금 부르는 말	실체 [추정]	누가 쓰나	갈라 부를 이름 (제안)
토큰 (JWT)	/api/token/pair 발급 · dj-core 거절	? — 실측 대상	jwt_pair — 처분 전까지
토큰 (user.token)	dj-core가 기대하는 것 (core/auth.py:38)	웹 UI? 게이트가 들어간 길?	user_token
토큰 (API 키)	F-05 외부 App 키 · 테넌트 귀속	U6 외부 연계	api_key (이미 대장에 — 맨 이름 금지)
세션	브라우저 세션 쿠키	웹 UI (있다면)	web_session

왜 지금인가. 모바일 3장은 온보딩 표에서 가장 낮은 U3(25%)을 여는 일이고, 그 첫 화면이 로그인이다. 401을 도달로 읽던 게이트가 이제 막 고쳐졌는데, 같은 401 위에 모바일을 세우면 화면은 뜨고(착시 ㉔) 사용자는 못 들어간다. P-5 바로 뒤, 모바일 바로 앞이다.

순서와 보고

3 실행 순서 — Code 권고(P-5 먼저)를 받는다

기반 2 : 제품 8 · 최소 5절 · 쓰기 면은 P-8

- 1 P-5 MinIO — compose 1개 · lock · 자격증명 로컬 .env(이름만 저장소). media-data 200 + 객체 1 · route-alive 빨강→초록, 사유 「MinIO 200」. **기반** ①
- 2 P-15 인증 경로 대장 + /api/token/pair 처분. **기반** ② · **모바일의 문턱**
- 3 P-16 결합 규칙 + 오탐 ②③④ — 쓰기 면 셋 → P-8 등록 먼저. **제품**
- 4 P-13 W1 프리셋 3 → **모바일 M1·M2·M3** — P-15 확정 길로 로그인 · 시드 1건 왕복 · 스크린샷 4장 · data_source=seed. **제품** · **U3**
- 5 /handover 본문 → 평상 운영 ① 죽은 카메라 · ④ 저장 용량 → ② 순회. **제품**
- 6 HWPX 일일 1종 — (a)(b)(c) 실측 · (d) 미검증 · samples/. **제품** · **U4**
- 7 P-3 봉투 — 기반 예산 안이면. 넘으면 다음 턴, 그렇게 보고. **기반** ③
- 8 P-11 onboarding_48.md 실측 + 어긋난 행 N건 · PRD 절 표. 여기서 멈추고 보고. **두 수**

턴이 1~2에서 끝나도 **옳은 보고다** — 직전 턴이 「1번을 규약대로 끝내는 데 턴을 썼다」고 적은 것처럼. 다만 그때는 3~5 중 무엇을 다음에 먼저 할지 **Code 권고 한 줄**을 붙여라. 이번 P-5 권고처럼 — 받았다.

4 보고 형식

줄	내용
첫 줄	「잠고 통과 N · 잠고 실패 N · 못 잠 N · 대기 N」 + 빨강→초록 사유(P-10). route-alive가 초록이면 사유는 「MinIO 200」 이어야 한다
계약	「커널 표 갱신 N · 상대방 대기 6절」
두 수	「상용 가중 N% (절 N) · 온보딩 N% (48행)」 — 온보딩은 P-11 뒤부터, 그 전엔 「미측정」. 세종 판정을 옮기지 않는다
지시 이행	이름으로. 이미 있음/부분/없음 → 한 일 → 증거. green N/M. 쓰기 면 대장(P-8) · 인증 경로 대장(P-15) · 대응표 P-n ↔ D-정본 · 세종 오류 N건

5 대표개

게이트가 처음으로 옳은 색을 냈습니다 — 초록 6 · 빨강 1(MinIO 부재) · 회색 0 · 대기 2. 빨강은 다음 턴 첫 일(MinIO)로 풀린다. 시크릿 스캔이 예시 파일의 하드코딩 토큰 1건을 잡아 비웠습니다 — 실제 환경 값이었는지 확인 후 필요하면 무효화하고, 저장소 이력은 다시 쓰지 않습니다.

미결 그대로: 알림 채널(문자/카톡/앱) · HWPX 한컴 열림 확인. 온보딩 %는 Code가 실측으로 확정된 뒤 병기합니다 — 이번 보고에 제 판정 44%를 그대로 옮기지 않은 것은 옳은 일이었습니다.

불변 제약 (변동 없음 + 1). .env 실제 값 금지·형식 검증(D-204 — MinIO·게이트 자격증명 포함) · 유출은 무효화, 이력 재작성 금지(D-004) · 권한 우회 목록 추가 금지(D-103) · 격리 시험 비활성 금지(D-105) · 탐침 없는 쓰기 면 금지(P-8) · 무계정 링크 금지 · App 총_base_manager 금지(시드 포함) · **죽은 인증 길 위에 화면 금지(P-15)** · dj-core/rj-core 직접 수정 금지(D-207 — core/auth.py 포함) · 운영 서버 로그인 금지 · dry-run(D-209) · 구간 티켓 서명(계약 11조) · 실제 화면 + data_source(D-347·P-9) · 래치(D-311) · lock(D-387) · 시험을 고쳐 초록 만들지 않는다(D-327) · 판정 불가능 회색(P-12) · **거절은 도달이 아니다(착시 ㉑).**